Introduktion til software sikkerhed

Del 2 – System mål.

Af Martin Edwin Schjødt Nielsen

University College

System mål

Formålet med systemmål er at klarlægge, hvad et system skal kunne for at understøtte de forretningsmæssige behov. I kontekst af sikkerhed er det vigtigt at skabe overblik over, hvilke forretningsaktiver der skal beskyttes, hvilket kan udledes fra systemets brugstilfælde. Figur 3 viser et eksempel på et brugstilfælde.

Brugstilfælde 14: Opret en indlånskonto til en privat kunde.

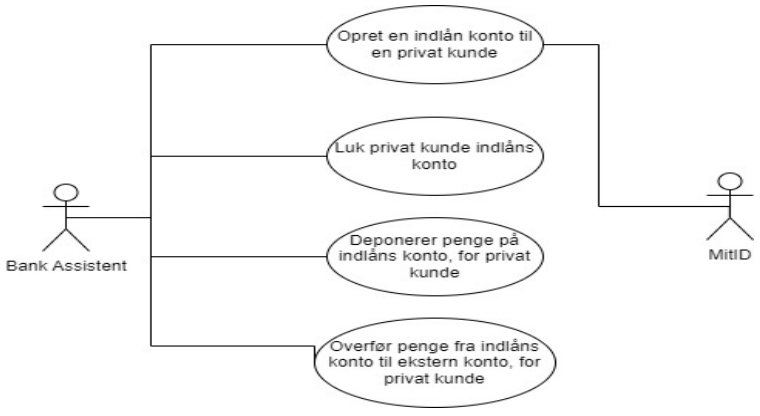
Forudsætning: Privat kunden har identificeret sig selv med Pas eller kørekort.

Bankassistenten indtaster privat kundens Fornavn, Mellemnavn (Hvis aktuelt), Efternavn, Køn, CPR-nummer, Bopæls gadenavn, Bopæls hus el. lejligheds nummer. Herefter afventer systemet MitID godkendelse fra privatkunden, og når privatkunden har godkendt kontooprettelsen med MitID sender systemet en bekræftelses mail til bankassistents arbejdes E-mail konto (@bigbank domæne) som indeholder privat kundens kundenummer samt konto nummer på den oprettede konto. Systemet sender også en bekræftelses mail til den E-boks konto som er tilknyttet kundens CPR-nummer, mailen indeholder kontonummer samt henvisning til net bank guides.

Figur 1 Eksempel på et brugstilfælde

For at sikre en pragmatisk anvendelse af brugstilfælde bør der kun anvendes et relativt sammenfattet format som vist i Figur 3. Brugstilfælde beskriver det forretningsmæssige formål, som systemet understøtter, samt aktiver. I dette tilfælde kan selve indlånskontoen betragtes som et aktiv.

Det er også vigtigt at klarlægge, hvilke eksterne afhængigheder systemet har. Ud fra brugstilfældet i Figur 3 kan det udledes, at systemet har interaktion med MitID, som er en støttende aktør, som systemet er afhængigt af og kommunikerer med. For at danne et overblik over alle de identificerede brugstilfælde kan et simpelt brugstilfældediagram udarbejdes. Figur 4 viser et eksempel på et brugstilfældediagram.



Figur 2 Brugstilfælde diagram

Det er vigtigt at understrege, at diagrammet skal være simpelt. Abstraktionsniveauet i diagrammet tager udgangspunkt i de overordnede systemmål for forretningen (også kaldet højniveau krav).

UML som notations form kan være et godt værktøj. Men man skal dog helst undgå at det kræver specialviden at læse et diagrammet. Derfor bør notationer som *Include* og *Extend* for så vidt muligt undgås, da disse kan være svære at forstå for personer uden indsigt i UML-notation. Altså man bør søge at lave diagrammerne på et højt abstraktionsniveau, når brugstilfælde anvendes til at definere system mål.

Når der indledningsvist er dannet et overblik over systemmål (brugstilfælde), kan man begynde at identificere sikkerhedsmål ved at udlede misbrugstilfælde (gennemgås i del 3).

Ikke funktionelle krav.

Med udgangspunkt i FURPS afdækker brugstilfældene de funktionelle krav. De ikke-funktionelle krav, som kan benævnes URPS, dækker over:

- Usability
- Reliability
- Performance
- Supportability

De ikke-funktionelle krav påvirkes af sikkerhedsmålene. For eksempel kan kategorien Usability ofte komme i konflikt med krav om komplekse adgangskoder eller begrænset antal autentificeringsforsøg. Dette betyder, at jo strengere sikkerhed der håndhæves i et system, desto sværere bliver det for aktøren at nå sit mål med systemet (udførelse af et brugstilfælde)

Kategorien performance, og sikkerhedsmål der indebærer behovet for kryptering af data, kan også risikere at skabe konflikter, da kryptering typisk bruger flere systemressourcer. Dette kan resultere i, at systemet har længere reaktionstider.

System kontekst

Indtil videre er det blevet taget udgangspunkt i et system med helhed som kontekst. Man kan dog også vælge at indsnævre dette, og kigge på mindre dele af systemet. F.eks. kan man vælge at afgrænse et banksystem og bestemme konteksten til at kun være den del af systemet som håndterer indbetalinger fra privatkunder. Dette kan være en god fremgangsmåde hvis der er konkrete dele af systemet hvor sikkerhed er særlig kritisk. Eller hvis systemet har mange brugstilfælde og det er svært at holde overblik. Som udgangspunkt bør man altid starte med at fastslå hvad konteksten for system målene er.